

Humanity Token

Print 

Executive Summary

This security review was prepared by Quantstamp, the leader in blockchain security.

Type	ERC-20
Timeline	2025-01-07 through 2025-01-09
Language	Solidity
Methods	Architecture Review, Unit Testing, Functional Testing, Computer-Aided Verification, Manual Review
Specification	H Token Documentation 
Source Code	https://github.com/humanity-org/hp-basic-token  #b1ac8df 
Auditors	Cameron Biniamow Auditing Engineer

Documentation quality	High 
Test quality	Medium 
Total Findings	1  Fixed: 1
High severity findings 	0
Medium severity findings 	0
Low severity findings 	0

Undetermined severity findings ⓘ	0
Informational findings ⓘ	1 Fixed: 1

Summary of Findings

Humanity token is an upgradeable ERC-20 token deployed behind a [Transparent Upgradeable Proxy](#). Currently, the Humanity token restricts token minting and burning to only the Humanity token contract owner.

Quantstamp reviewed the `BMToken.sol` and `Proxies.sol` contracts. During the review, the audit team did not identify any critical issues; however, one informational issue is listed regarding adherence to best practices.

Update: All issues listed in this report have been fixed in commit `4914653776698f470a95ca392f112af603060fba`.

Update 2025-07-11: The following minor changes occurred in commit `4fd677686f87cd26cbd9ce27842721c6b789293e`:

- File name: `BMToken.sol` was changed to `HToken.sol`
- License: The `HToken.sol` and `Proxies.sol` contracts changed from unlicensed to MIT
- Compiler: The compiler version for `Proxies.sol` was changed from `0.8.0` to `0.8.28`

ID	HUM-1
DESCRIPTION	Secrets in Configuration File
SEVERITY	• Informational ⓘ
STATUS	Fixed

Assessment Breakdown

Quantstamp's objective was to evaluate the repository for security-related issues, code quality, and adherence to specification and best practices.

Only features that are contained within the repositories at the commit hashes specified on the front page of the report are within the scope of the audit and fix review. All features added in future revisions of the code are excluded from consideration in this report.

Possible issues we looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Mishandled exceptions and call stack limits
- Unsafe external calls
- Integer overflow / underflow
- Number rounding errors
- Reentrancy and cross-function vulnerabilities
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting

Methodology

1. Code review that includes the following
 1. Review of the specifications, sources, and instructions provided to Quantstamp to make sure we understand the size, scope, and functionality of the smart contract.
 2. Manual review of code, which is the process of reading source code line-by-line in an attempt to identify potential vulnerabilities.
 3. Comparison to specification, which is the process of checking whether the code does what the specifications, sources, and instructions provided to Quantstamp describe.
2. Testing and automated analysis that includes the following:
 1. Test coverage analysis, which is the process of determining whether the test cases are actually covering the code and how much code is exercised when we run those test cases.
 2. Symbolic execution, which is analyzing a program to determine what inputs cause each part of a program to execute.
3. Best practices review, which is a review of the smart contracts to improve efficiency, effectiveness, clarity, maintainability, security, and control based on the established industry and academic practices, recommendations, and research.
4. Specific, itemized, and actionable recommendations to help you take steps to secure your smart contracts.

Scope

Files Included

- `contracts/BMToken.sol`
- `contracts/Proxies.sol`

Files Excluded

- `contracts/test/BMTokenUpgrade.sol`

Operational Considerations

1. The `BMToken` contract is upgradeable, and the contract owner can alter the contract code to change the token's behavior.
2. The owner of the `BMToken` contract can burn tokens from any address without approval.

Key Actors And Their Capabilities

- `BMToken.sol`
 - `owner`
 - Can mint an uncapped amount of Humanity tokens to any address.
 - Can burn any amount of Humanity tokens from any address.
 - Can transfer ownership of the Humanity token to another address.
 - Can renounce their ownership of the Humanity token, which prevents the execution of all privileged functionality in the Humanity token.
- `Proxies.sol`
 - `TransparentUpgradeableProxy`
 - `admin`
 - Can upgrade the implementation contract, which can alter the behavior of the token.
 - `ProxyAdmin`
 - `owner`
 - Can call the `TransparentUpgradeableProxy` contract and upgrade the implementation contract.
 - Can transfer ownership of the `ProxyAdmin` contract to another address.
 - Can renounce their ownership of the `ProxyAdmin` contract, preventing future upgrades of the `TransparentUpgradeableProxy` implementation contract.

Findings

HUM-1 Secrets in Configuration File

- **Informational** ⓘ **Fixed**



Update

The client fixed the issue in commit

4914653776698f470a95ca392f112af603060fba and provided the following explanation:

The keys used in the configuration file were revoked and we are instead including them in .env and loading them in when hardhat runs.

File(s) affected: `hardhat.config.ts`

Description: The Hardhat configuration file lists an Etherscan API key in plain text. An attacker could use the API key to consume the team's Etherscan call credits, causing a DoS and financial loss.

Recommendation: Keep the keys in a hidden file not exposed to the public (e.g., .env) and fetch them using known tools like dotenv. Additionally, the team should create new keys if this repository is open-sourced since keys will be exposed in the git history.

Definitions

- **High severity** – High-severity issues usually put a large number of users' sensitive information at risk, or are reasonably likely to lead to catastrophic impact for client's reputation or serious financial implications for client and users.
- **Medium severity** – Medium-severity issues tend to put a subset of users' sensitive information at risk, would be detrimental for the client's reputation if exploited, or are reasonably likely to lead to moderate financial impact.
- **Low severity** – The risk is relatively small and could not be exploited on a recurring basis, or is a risk that the client has indicated is low impact in view of the client's business circumstances.
- **Informational** – The issue does not pose an immediate risk, but is relevant to security best practices or Defence in Depth.
- **Undetermined** – The impact of the issue is uncertain.
- **Fixed** – Adjusted program implementation, requirements or constraints to eliminate the risk.
- **Mitigated** – Implemented actions to minimize the impact or likelihood of the risk.
- **Acknowledged** – The issue remains in the code but is a result of an intentional business or design decision. As such, it is supposed to be addressed outside the programmatic means, such as: 1) comments, documentation, README, FAQ; 2) business processes; 3) analyses showing that the issue shall have no negative consequences in practice (e.g., gas analysis, deployment settings).

Appendix

File Signatures

The following are the SHA-256 hashes of the reviewed files. A file with a different SHA-256 hash has been modified, intentionally or otherwise, after the security review. You are cautioned that a different SHA-256 hash could be (but is not necessarily) an indication of a changed condition or potential vulnerability that was not within the scope of the review.

Files

- 4d6...550 ./contracts/Proxies.sol
- 361...1a4 ./contracts/BMToken.sol

Tests

- 95b...f1b ./tests/BMToken.ts

Test Suite Results

The test suite was run with the following command. All test cases were run successfully.

```
npx hardhat test
```

BMToken

Deployment

✓ **Should** properly work (1501ms)

1 passing (2s)

Code Coverage

Test coverage was obtained by running the following command. Branch coverage is low at 50%; the audit team recommends improving the test suite to increase branch coverage to at least 90%.

```
npx hardhat coverage
```

File	% Stmts	% Branch	% Funcs
contracts/	100	50	100
BMToken.sol	100	50	100
Proxies.sol	100	100	100
All files	100	50	100

Changelog

- 2025-01-09 - Initial report
- 2025-01-13 - Final report
- 2025-07-11 - Report update

About Quantstamp

Quantstamp is a global leader in blockchain security. Founded in 2017, Quantstamp's mission is to securely onboard the next billion users to Web3 through its best-in-class Web3 security products and services.

Quantstamp's team consists of cybersecurity experts hailing from globally recognized organizations including Microsoft, AWS, BMW, Meta, and the Ethereum Foundation. Quantstamp engineers hold PhDs or advanced computer science degrees, with decades of combined experience in formal verification, static analysis, blockchain audits, penetration testing, and original leading-edge research.

To date, Quantstamp has performed more than 500 audits and secured over \$200 billion in digital asset risk from hackers. Quantstamp has worked with a diverse range of customers, including startups, category leaders and financial institutions. Brands that Quantstamp has worked with include Ethereum 2.0, Binance, Visa, PayPal, Polygon, Avalanche, Curve, Solana, Compound, Lido, MakerDAO, Arbitrum, OpenSea and the World Economic Forum.

Quantstamp's collaborations and partnerships showcase our commitment to world-class research, development and security. We're honored to work with some of the top names in the industry and proud to secure the future of web3.

Notable Collaborations & Customers:

- Blockchains: Ethereum 2.0, Near, Flow, Avalanche, Solana, Cardano, Binance Smart Chain, Hedera Hashgraph, Tezos
- DeFi: Curve, Compound, Maker, Lido, Polygon, Arbitrum, SushiSwap
- NFT: OpenSea, Parallel, Dapper Labs, Decentraland, Sandbox, Axie Infinity, Illuvium, NBA Top

Shot, Zora

- Academic institutions: National University of Singapore, MIT

Timeliness of content

The content contained in the report is current as of the date appearing on the report and is subject to change without notice, unless indicated otherwise by Quantstamp; however, Quantstamp does not guarantee or warrant the accuracy, timeliness, or completeness of any report you access using the internet or other means, and assumes no obligation to update any information following publication or other making available of the report to you by Quantstamp.

Notice of confidentiality

This report, including the content, data, and underlying methodologies, are subject to the confidentiality and feedback provisions in your agreement with Quantstamp. These materials are not to be disclosed, extracted, copied, or distributed except to the extent expressly authorized by Quantstamp.

Links to other websites

You may, through hypertext or other computer links, gain access to web sites operated by persons other than Quantstamp. Such hyperlinks are provided for your reference and convenience only, and are the exclusive responsibility of such web sites' owners. You agree that Quantstamp are not responsible for the content or operation of such web sites, and that Quantstamp shall have no liability to you or any other person or entity for the use of third-party web sites. Except as described below, a hyperlink from this web site to another web site does not imply or mean that Quantstamp endorses the content on that web site or the operator or operations of that site. You are solely responsible for determining the extent to which you may use any content at any other web sites to which you link from the report. Quantstamp assumes no responsibility for the use of third-party software on any website and shall have no liability whatsoever to any person or entity for the accuracy or completeness of any output generated by such software.

Disclaimer

The review and this report are provided on an as-is, where-is, and as-available basis. To the fullest extent permitted by law, Quantstamp disclaims all warranties, expressed implied, in connection with this report, its content, and the related services and products and your use thereof, including, without limitation, the implied warranties of merchantability, fitness for a particular purpose, and non-infringement. You agree that access and/or use of the report and other results of the review, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your sole risk. FOR AVOIDANCE OF DOUBT, THE REPORT, ITS CONTENT, ACCESS, AND/OR USAGE THEREOF, INCLUDING ANY ASSOCIATED SERVICES OR MATERIALS, SHALL NOT BE CONSIDERED OR RELIED UPON AS ANY FORM OF FINANCIAL, INVESTMENT, TAX, LEGAL, REGULATORY, OR OTHER ADVICE. This report is based on the scope of materials and documentation provided for a limited review at the time provided. You acknowledge that Blockchain technology remains under development and is subject to unknown risks and flaws and, as such, the report may not be complete or inclusive of all vulnerabilities. The review is limited to the materials identified in the report and does not

extend to the compiler layer, or any other areas beyond the programming language, or programming aspects that could present security risks. The report does not indicate the endorsement by Quantstamp of any particular project or team, nor guarantee its security, and may not be represented as such. No third party is entitled to rely on the report in any way, including for the purpose of making any decisions to buy or sell a product, service or any other asset. Quantstamp does not warrant, endorse, guarantee, or assume responsibility for any product or service advertised or offered by a third party, or any open source or third-party software, code, libraries, materials, or information to, called by, referenced by or accessible through the report, its content, or any related services and products, any hyperlinked websites, or any other websites or mobile applications, and we will not be a party to or in any way be responsible for monitoring any transaction between you and any third party. As with the purchase or use of a product or service through any medium or in any environment, you should use your best judgment and exercise caution where appropriate.

